

UA 6.- Legislación y Normativa en seguridad de la información

1.- Legislación

Configurado en **cuatro apartados**:

1.1.- Infraestructuras críticas

1.2.-Protección de datos personales

1.3.-Ciberseguridad y

1.4.-Comunicaciones y administración electrónica

1.1. Infraestructuras críticas

- Ley 8/2011, de 28 de abril, se establecen las **medidas para la protección de las infraestructuras críticas**.
- Real Decreto 704/2011, de 20 de mayo, se aprueba el **Reglamento de protección de las infraestructuras críticas**.
- Resolución de 8 de septiembre de 2015, de la secretaría de Estado de Seguridad, se aprueban los **nuevos contenidos mínimos de los planes de seguridad del operador de infraestructuras críticas** y de sus planes de protección específicos.

UA 6.- Legislación y Normativa en seguridad de la información

1.2. Protección de datos personales - Antecedentes

- Ley Orgánica 5/92 de Regulación del tratamiento automatizado de los datos de carácter personal de 29 de octubre (**LORTAD**): sustituida posteriormente por la LOPD, supuso la primera ley española (y en el ámbito mundial) que regulaba específicamente los datos de carácter personal.
- Directiva 95/46 CE de 24 de octubre del Parlamento europeo y del Consejo relativa a la **protección de las personas físicas en lo referente al tratamiento de datos personales** y a la libre circulación de estos datos. **Motivó el desarrollo de la LOPD.**
- Ley Orgánica 15/1999 de 13 de diciembre de **Protección de datos de carácter personal (LOPD)**: su objetivo es **regular** el **tratamiento** de los **datos** y **ficheros** de carácter **personal**, independientemente del **soporte** en el que son tratados (automatizados y no automatizados), los **derechos** de los **ciudadanos** sobre ellos y las **obligaciones** de quienes los **crean** o **tratan**, al tiempo que **traspone** la Directiva europea 95/46. Reemplazada por la publicación de la Ley Orgánica 3/2018, de 5 de diciembre.
- Real Decreto 1720/2007, de 21 de diciembre, por el que se aprueba el **Reglamento de desarrollo de la LOPD**, de protección de datos de carácter personal. Fuente de referencia fundamental para determinar los requisitos técnicos a implementar en función del nivel de los datos a proteger.

UA 6.- Legislación y Normativa en seguridad de la información

1.2. Protección de datos personales – Legislación actual

- **Reglamento** (UE) 2016/679 del Parlamento Europeo y del consejo de 27 de abril de 2016 relativo a la **protección** de las **personas físicas** en lo que respecta al **tratamiento** de **datos personales** y a la **libre circulación** de estos datos y que deroga la Directiva 95/46/CE (**Reglamento general de protección de datos**)

Supone una **importante actualización** en la **normativa** de protección de **datos personales** en la **UE** y es de aplicación directa, sin necesidad de realizar trasposición a la legislación nacional. El desarrollo de este reglamento parte de **dos conceptos** principales:

1. **Dato personal**: “**toda información** sobre una persona **física**, identificada o identificable”, entendiéndose como persona física **identificable** a toda persona cuya **identidad** pueda determinarse **directa** o **indirectamente**. Esto significa que se **consideran datos personales**, entre otros: **nombre**, **DNI**, datos de **localización**, dirección **IP**, **fisiología**, **genética**, etc.
2. **Tratamiento**: “Cualquier **operación** o conjunto de operaciones realizadas sobre **datos personales** o conjuntos de datos personales, ya sea por **procedimientos automatizados** o **no automatizados**, así como la recogida, organización, estructuración, conservación, adaptación o modificación, extracción, consulta utilización, comunicación por transmisión, difusión o cualquier otra forma de habilitación de acceso, cotejo, interconexión, limitación, supresión o destrucción.”

UA 6.- Legislación y Normativa en seguridad de la información

Este nuevo **RGPD**, además de profundizar en la **protección** de los **derechos** de las **personas** en relación a los datos que las identifican, incorpora algunas novedades:

- Creación de la figura del **Delegado de Protección de Datos**, y establecimiento de las condiciones para su obligada designación en determinadas organizaciones.
- El **anterior** modelo, basado en **ficheros de datos**, **evoluciona** hacia el **tratamiento de datos**. El enfoque de la nueva normativa **cambia** radicalmente las **funciones** de la **Agencia** de Protección de Datos, **ya no se inscriben** los **ficheros** y el **enfoque** se centra en el “**tratamiento**”.
- **Obligatoriedad de comunicación de incidentes**: Notificar las violaciones de datos a las autoridades de supervisión y a las personas afectadas dentro de 72 horas después de haber tenido conocimiento de ello.
- El régimen sancionador incorpora **sanciones** de hasta **20.000.000 €** o de una cuantía equivalente al **4 % del volumen de negocio total anual** del ejercicio anterior, si el infractor es una empresa.
- Incorpora la **obligación a todas las organizaciones de analizar las vulnerabilidades informáticas y posibles brechas de seguridad** lógica con el objeto de seleccionar e **implementar las soluciones tecnológicas** más óptimas para impedir, bloquear o neutralizar los ataques.

UA 6.- Legislación y Normativa en seguridad de la información

- Establece las **condiciones** por las que las **organizaciones** deberán efectuar una **evaluación del impacto** que los tratamientos de datos que realizan tienen sobre la protección de datos personales.

Aunque este Reglamento es de aplicación directa en todos los países miembros, en **España** ha **obligado** a **actualizar** la **LOPD**, publicándose en diciembre de 2018 la:

- **Ley Orgánica 3/2018**, de 5 de diciembre, de **Protección de datos personales y garantía de los derechos digitales (LOPDyGDD)**. Se adapta al Reglamento (UE) 2016/679 y sustituye a la LOPD.

Incorpora las directrices del RGPD, aplicando el enfoque hacia el “**tratamiento de datos**” y **modificando** las **misiones** principales de la **Agencia Española de Protección de Datos**.

UA 6.- Legislación y Normativa en seguridad de la información

1.3. Ciberseguridad

- Ley 34/2002 de **Servicios de la sociedad de la información y de comercio electrónico (LSSI-CE)**: sienta las **bases del régimen jurídico** de los **servicios de la sociedad de la información** y de la **contratación** por medios electrónicos.

En relación a esta Ley hay algunos aspectos especialmente destacables:

- Incluye las **obligaciones** de los **prestadores de servicios**, de **obligado** cumplimiento para los casos en los que se obtiene un **beneficio económico** como consecuencia de la prestación de dichos servicios.
- **Regula** las comunicaciones **comerciales** por medios electrónicos.
- Establece un régimen **sancionador**.
- Incluye aspectos relativos a la **accesibilidad** en las **webs** de las Administraciones públicas.
- Regula la asignación de **nombres de dominio** bajo **.es**
- Real Decreto 3/2010, de 8 de enero, por el que se regula el **Esquema Nacional de Seguridad** en el ámbito de la Administración Electrónica. Se desarrollará más adelante, pues define el **marco de seguridad de la Administración Pública** y con afectación **incluso** a las **empresas** que se relacionan con la Administración.

UA 6.- Legislación y Normativa en seguridad de la información

- Real Decreto 951/2015, de 23 de octubre, de **modificación** del Real Decreto 3/2010, de 8 de enero, por el que se regula el **Esquema Nacional de Seguridad** en el ámbito de la Administración Electrónica.
- Real Decreto 4/2010, de 8 de enero, por el que se regula el **Esquema Nacional de Interoperabilidad** en el ámbito de la Administración Electrónica.
- Real Decreto 381/2015, de 14 de mayo, por el que se establecen **medidas contra el tráfico no permitido** y el tráfico **irregular** con **fines fraudulentos** en comunicaciones electrónicas.
- **Directiva NIS:** Directiva (UE) 2016/1148 del Parlamento Europeo y del Consejo, de 6 de julio de 2016 relativa a las medidas destinadas a **garantizar un elevado** nivel común de **seguridad** de las **redes y sistemas de información** de la **Unión Europea**.
- **Trasposición de la Directiva NIS** al ámbito nacional: Real Decreto-ley 12/2018, de 7 de septiembre, de **seguridad de las redes y sistemas de información**.

Además de **regular** la **seguridad** de las **redes y sistemas** de información destinados a proporcionar **servicios esenciales** y digitales, establece un **sistema de notificación de incidentes obligatorio**.

UA 6.- Legislación y Normativa en seguridad de la información

Se contemplan **cuatro objetivos** principales:

- **Gestionar el riesgo.**
- **Proteger** contra los posibles **ciberataques**.
- **Detectar eventos** de ciberseguridad.
- **Minimizar el impacto** de los incidentes.

La Directiva NIS establece **cinco medidas** principales:

1. **Obliga** a todos los **estados** miembros a **definir** una **Estrategia Nacional de Seguridad de las redes y los sistemas de información** (Estrategia de Ciberseguridad Nacional)
2. Define la **creación** de un **grupo de cooperación** para consensuar una **estrategia común** y para garantizar el intercambio de información entre los estados miembros.
3. Conlleva la **creación de una red CSIRT** (Equipos de Respuesta a Incidentes de Seguridad Informática). Recordemos que CERT y CSIRT son la misma cosa.
4. Requiere que se establezcan **condiciones de seguridad para los operadores de servicios esenciales** y los **proveedores de servicios digitales** (persona jurídica que preste un servicio digital)

UA 6.- Legislación y Normativa en seguridad de la información

5. Implica **obligaciones para las autoridades nacionales** en todas las tareas relacionadas con la **seguridad de redes y sistemas**.

La **trasposición** de esta Directiva se hizo a través del Real Decreto-Ley 12/2018, de 7 de septiembre, de **seguridad de las redes y sistemas de información**. Entre otros aspectos, este Real Decreto-Ley:

- Identifica los **Operadores de servicios esenciales** y las **medidas de seguridad** que han de aplicar.
 - Las **Autoridades competentes**.
 - Identifica los **CSIRT de referencia** (**CCN-CERT** para organismos públicos, **INCIBE-CERT** para los privados y la red académica y **ESPDEF-CERT** para los organismos de defensa)
 - Asigna al **CCN-CERT** la **coordinación** y respuesta técnica en casos de **especial gravedad**.
-
- **Estrategia Nacional de Ciberseguridad:** Orden PCI/487/2019, de 26 de abril por la que se publica la Estrategia Nacional de Ciberseguridad 2019, aprobada por el Consejo de Seguridad Nacional.

UA 6.- Legislación y Normativa en seguridad de la información

1.4. Comunicaciones y administración electrónica

- Ley 30/1992 de **Régimen jurídico de las administraciones públicas y del procedimiento administrativo común**: incluye ya en su contenido la **obligación** para las **Administraciones Públicas** para aplicar técnicas y medios **electrónicos**, informáticos y telemáticos para el desarrollo de su actividad. Establece además la **validez** de los **documentos** emitidos por medios **electrónicos**, informáticos o telemáticos siempre que se asegure su autenticidad, integridad y conservación.
- Real Decreto 263/1996, de 16 de febrero por el que se regula la **utilización de técnicas electrónicas, informáticas y telemáticas por la Administración General del Estado**: desarrolla el artículo 45 de la Ley 30/92, vinculado al uso de medios telemáticos por parte de la Administración Pública.
- **Directiva** 1999/93/CE de 13 de diciembre por la que se establece un **marco comunitario para la firma electrónica**: establece los criterios para el reconocimiento jurídico de la firma digital. Se incluyen nuevos conceptos tales como: firma electrónica, firma electrónica avanzada y certificado reconocido.
- **Directiva** 2000/31/CE de 8 de junio sobre el **comercio electrónico**: su objetivo es reforzar la **seguridad jurídica** del comercio electrónico estableciendo un marco jurídico ajustando los servicios de la sociedad de la información a los principios del mercado interior. Introduce referencias a la contratación en línea y al spam como comunicaciones comerciales no autorizadas.

UA 6.- Legislación y Normativa en seguridad de la información

- Real Decreto 209/2003, de 21 de febrero por el que se regulan los **registros y las notificaciones telemáticas**, así como la utilización de medios telemáticos para la sustitución de la aportación de certificados por los ciudadanos.
- Ley 59/2003 de 19 de diciembre de **Firma Electrónica**. En la UA 1 desarrollamos algunos conceptos de esta ley, como la distinción entre firma electrónica reconocida y avanzada.
- **Directiva** 2004/18/CE del Parlamento Europeo y del Consejo de 31 de marzo de 2004, sobre coordinación de los **procedimientos de adjudicación de los contratos públicos** de obras, de suministro y de servicio. Introduce la **igualdad** entre los **medios electrónicos** y los **tradicionales**, así como el concepto de “subasta electrónica”.
- Ley 11/2007, de 22 de junio, de **Acceso electrónico de los ciudadanos a los servicios públicos (LAEOSP)**: supone un **impulso** a la relación de los **ciudadanos** con las **Administraciones Públicas** por **medios electrónicos** y establece el **mandato** de regular la seguridad electrónica que condujo a promulgar el **ENS**.
- Ley 56/2007, de 28 de diciembre, de Medidas de impulso de la sociedad de la información: destaca por los aspectos relativos a la **factura electrónica**.
- Ley 25/2007, de 18 de octubre, de **conservación de datos** relativos a las comunicaciones electrónicas y a las **redes públicas** de comunicaciones.

UA 6.- Legislación y Normativa en seguridad de la información

- Real Decreto 1671/2009, de 6 de noviembre, por el que se **desarrolla parcialmente** la Ley 11/2007 de 22 de junio, de acceso electrónico de los ciudadanos a los servicios públicos, **LAECSP**.
- Ley 9/2014, de 9 de mayo, **General de Telecomunicaciones**.
- Ley 39/2015, de 1 de octubre, del **Procedimiento Administrativo común** de las administraciones públicas.
- Ley 40/2015, de 1 de octubre, de **Régimen Jurídico del sector público**.

Estas dos últimas leyes producen una verdadera **revolución** en la interacción entre empresas, ciudadanos y las AAPP. Establecen la **obligatoriedad** de las **entidades jurídicas** de realizar todos los trámites por **medios electrónicos** y los **derechos** de los **ciudadanos** (personas físicas) a **tramitar electrónicamente**. Se promueve la creación de registros electrónicos con asistencia al ciudadano.

- Directiva (UE) 2018/1972 del Parlamento Europeo y del Consejo de 11 de diciembre de 2018 por la que se establece el **Código Europeo de las Comunicaciones Electrónicas**.

UA 6: Legislación y Normativa en seguridad de la información

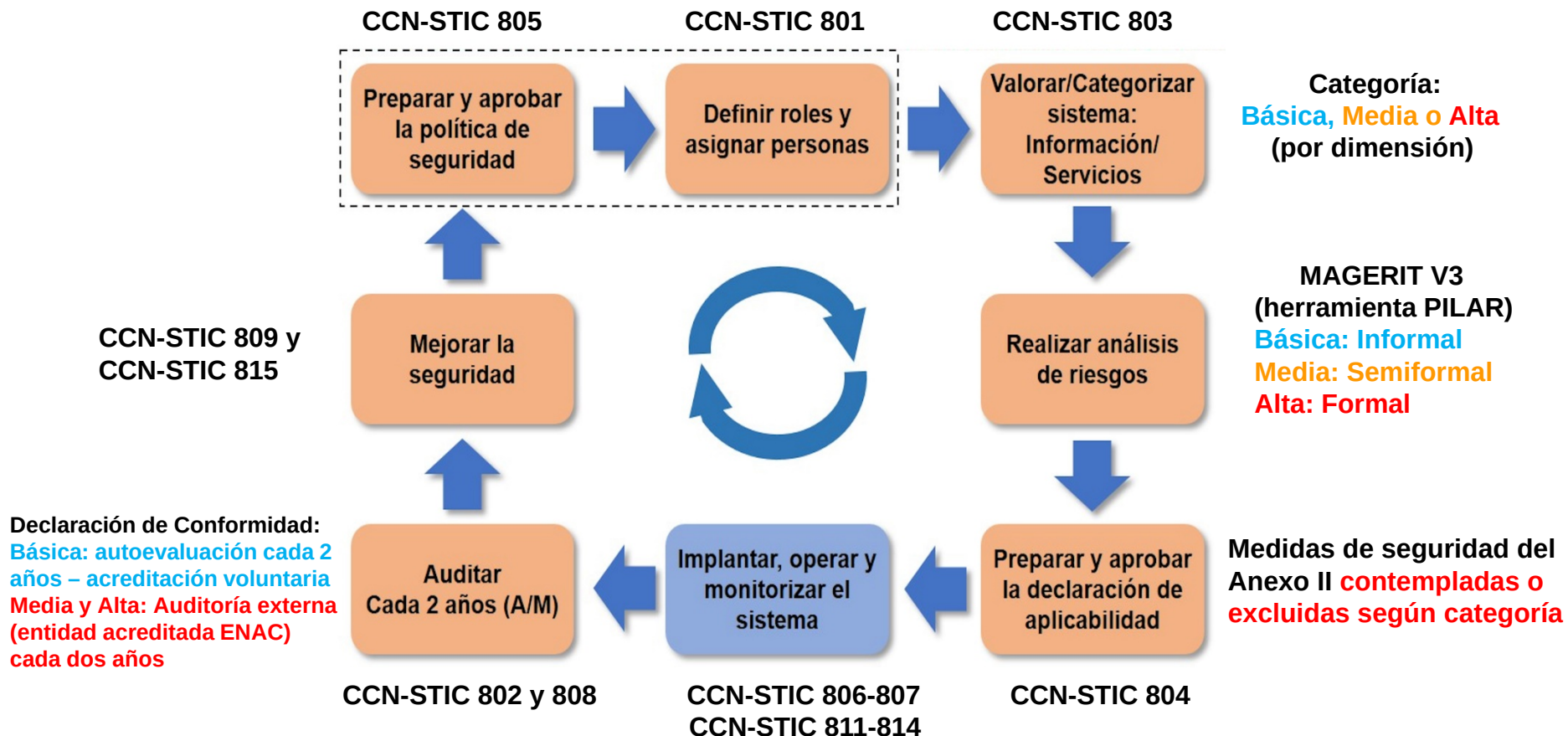
- **Esquema Nacional de Seguridad (RD 3/2010 y 951/2015)**
 - Define la política de seguridad en el uso de medios electrónicos, establece principios básicos y requisitos mínimos para proteger la información, garantizando las dimensiones de la seguridad – cumple el mandato de la LAECSP 11/2007
 - Sienta las bases de un marco normativo de la seguridad en redes y sistemas de las AAPP (Administraciones Públicas)
 - Objetivos básicos:
 - **Aportar confianza a los ciudadanos** en sus derechos y deberes con la Administración General del Estado (**AGE**) por medios telemáticos
 - **Establecer políticas de seguridad** en el uso de medios electrónicos
 - Crear un **marco común en las AAPP** en seguridad de la información
 - Establecer **un lenguaje homogéneo** que facilite la **interacción** entre **administraciones** y su comunicación a la **industria y empresas**

UA 6: Legislación y Normativa en seguridad de la información

- **Ámbito legal y de aplicación del ENS**
 - Es de **obligada aplicación en la AGE**: Ministerios, CCAAs, Admon local, Entidades y empresas públicas (universidades, organismos públicos, etc.)
 - Quedan **excluidos** sistemas que **traten** información **clasificada**
 - Cuando las **soluciones o servicios** en el ámbito del ENS sean proporcionados por **empresas privadas**, habrán de satisfacer sus exigencias legales, por tanto:
 - Toda **empresa privada** que proporcione **servicios a la AGE** ha de satisfacer (y acreditar) el **ENS**
- **Elementos Básicos del ENS**
 - Principios básicos y requisitos mínimos para proteger la información
 - Adopción de medidas **proporcionadas** a la naturaleza y tipología de los servicios a proteger (**categorización** de los sistemas según la información que manejan)
 - Comunicaciones electrónicas
 - Auditoría de Seguridad
 - Respuesta ante incidentes
 - Certificación de seguridad y conformidad de cumplimiento

UA 6: Legislación y Normativa en seguridad de la información

- Esquema General de implantación del ENS



UA 6: Legislación y Normativa en seguridad de la información

ESQUEMA NACIONAL DE SEGURIDAD 75 MEDIDAS DE SEGURIDAD

MARCO ORGANIZATIVO

El marco organizativo está constituido por un conjunto de medidas relacionadas con la organización global de la seguridad

4

POLÍTICA DE SEGURIDAD
NORMATIVA DE SEGURIDAD
PROCEDIMIENTOS DE SEGURIDAD
PROCESO DE AUTORIZACIÓN

MARCO OPERACIONAL

El marco operacional está constituido por las medidas a tomar para proteger la operación del sistema como conjunto integral de componentes para un fin

31

PLANIFICACIÓN
CONTROL DE ACCESO
EXPLOTACIÓN
SERVICIOS EXTERNOS
CONTINUIDAD DEL SERVICIO
MONITORIZACIÓN DEL SISTEMA

MEDIDAS DE PROTECCIÓN

Las medidas de protección, se centrarán en proteger activos concretos, según su naturaleza, con el nivel requerido en cada dimensión de seguridad.

40

INSTALACIONES E INFRAESTRUCTURAS
GESTIÓN DEL PERSONAL
PROTECCIÓN DE LOS EQUIPOS
PROTECCIÓN DE LAS COMUNICACIONES
PROTECCIÓN SOPORTES DE INFORMACIÓN
PROTECCIÓN APLICACIONES INFORMÁTICAS
PROTECCIÓN DE LA INFORMACIÓN
PROTECCIÓN DE LOS SERVICIOS

El Anexo II especifica las medidas mínimas aplicables según la categoría de los sistemas

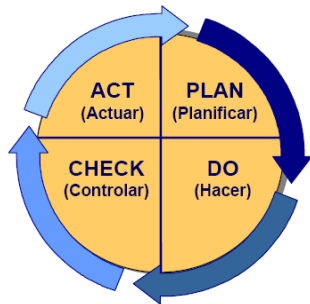
UA 6: Legislación y Normativa en seguridad de la información

- **La Norma ISO 27.001**

- Estándar internacional en **Sistemas de Gestión de Seguridad de la Información** (SGSI), definidos como *“una parte del sistema de gestión general, basada en un enfoque de riesgo empresarial, que se establece para crear, implementar, operar, supervisar, revisar, mantener y mejorar la seguridad de la información”*
- Pretende eliminar elementos subjetivos y desplegar “medibles” que aporten información objetiva de lo que ocurre en los SSII
- Un SGSI es un sistema de gestión que abarca: modelos organizativos, políticas, planificación, responsabilidades, procedimientos, procesos y recursos
- ISO 27001 concibe la Seguridad como un proceso en sí mismo
- Cuerpo principal: 5 aspectos fundamentales
 - Establecimiento del SGSI
 - Responsabilidad de la Dirección
 - Auditorías internas del SGSI
 - Revisión continua
 - Mejora del SGSI
- ISO 27001 es certificable, y se apoya en la ISO 27002 (Buenas prácticas)
- Todo ha de quedar documentado, para formalizar las instrucciones y facilitar su comunicación a toda la organización

UA 6: Legislación y Normativa en seguridad de la información

- Modelo operativo: CICLO DE DEMING (Plan Do Check Act)**

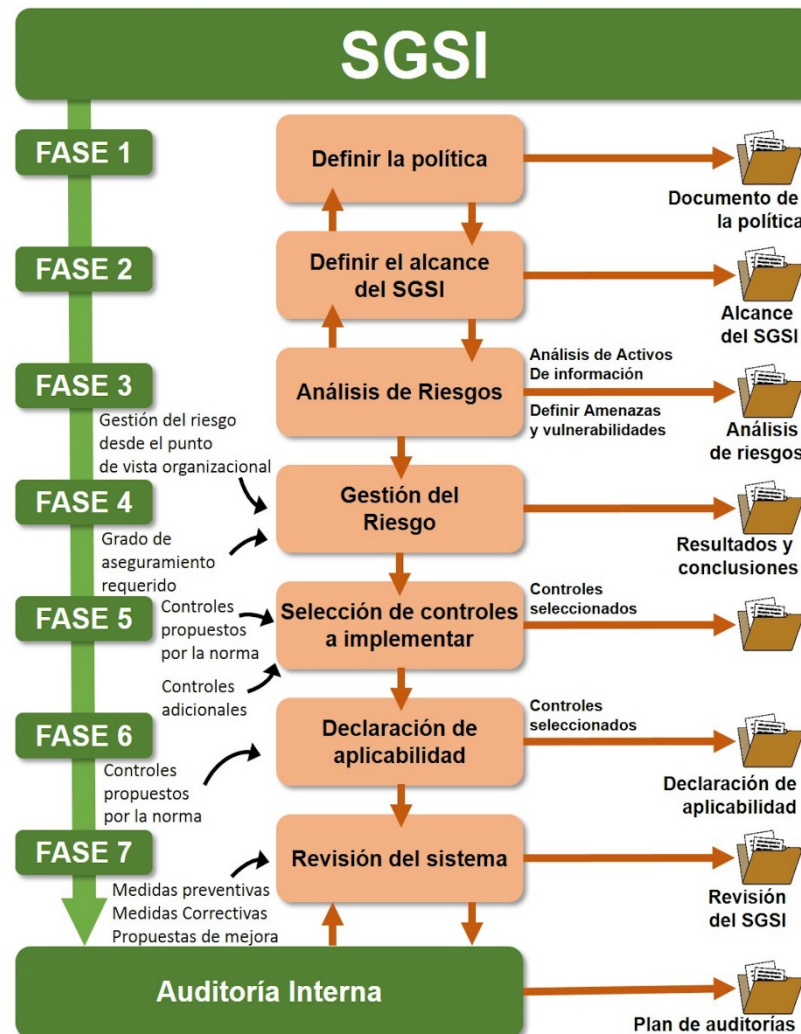


PLAN : Crear el SGSI - Identificar el proceso que se quiere mejorar - Recopilar datos para profundizar en el conocimiento del proceso - Análisis e interpretación de los datos - Establecer los objetivos de mejora - Detallar las especificaciones de los resultados esperados - Definir los procesos necesarios para conseguir estos objetivos, verificando las especificaciones	DO : Implementación del SGSI - Ejecutar los procesos definidos en el paso anterior - Documentar las acciones realizadas
CHECK : Supervisar el SGSI - Pasado un periodo de tiempo previsto de antemano, volver a recopilar datos de control y analizarlos, comparándolos con los objetivos y especificaciones iniciales, para evaluar si se ha producido la mejora esperada - Documentar las conclusiones	ACT : Mantener y Mejorar - Modificar los procesos según las conclusiones del paso anterior para alcanzar los objetivos con las especificaciones iniciales, si fuese necesario - Aplicar nuevas mejoras, si se han detectado en el paso anterior - Documentar el proceso

UA 6: Legislación y Normativa en seguridad de la información

- **La Norma ISO 27.001**
 - Documentación relativa a un SGSI
 - Organizada en 4 niveles : Políticas, Procedimientos, Instrucciones y Registros
 - Establecimiento del SGSI
 - Factores críticos: Compromiso de la dirección y planteamientos realistas
 - Requisitos previos establecidos en la norma
 - La misma ISO, legislación aplicable, contratos, reglamentos, negocio
 - Etapas para el establecimiento del SGSI
 - Fase I: Definir el alcance del SGSI
 - Fase II: Definir la política de Seguridad de la Organización
 - Fase III: Identificar los activos relacionados con el alcance definido
 - Fase IV: Definir el enfoque del análisis de riesgos (Detalle, Formalidad)
 - Fase V: Identificar los riesgos (Asociados a los activos)
 - Fase VI: Análisis de riesgos (Amenazas, Incidentes, Impacto)
 - Fase VII: Tratamiento de los riesgos (Mitigar, Asumir, Transferir, Eliminar)

UA 6: Legislación y Normativa en seguridad de la información



Fases en la implantación de un SGSI según ISO 27000

UA 6: Legislación y Normativa en seguridad de la información

- **La Norma ISO 27.001**

- Selección de controles

- Según el Anexo A, selección de controles y de Indicadores asociados

- Declaración de aplicabilidad

- Controles seleccionados, implementados y excluidos

- Implementación

- Definición de dos roles principales: Responsable y Comité

- Acciones: Plan de Tratamiento de Riesgos, Marco Normativo (Normas y Procedimientos), Formación y Concienciación, procedimientos y controles de detección y respuesta ante incidentes de seguridad

- Seguimiento

- Mediciones, Eficacia del SGSI (Auditorías), Eficacia de los controles, Revisión periódica, Actualización de Planes de seguridad

- Mejora Continua

- Implantar mejoras detectadas en fase anterior, acciones correctivas y preventivas, comunicación de acciones y mejoras

UA 6: Legislación y Normativa en seguridad de la información

- **La Norma ISO 27.002**
 - No es certificable, es un compendio de Buenas Prácticas
 - Presta soporte a la ISO 27001
 - 11 Capítulos, 39 categorías de seguridad (objetivos), 133 controles
 - Incluye metodología de Análisis y Gestión de Riesgos



UA 6: Legislación y Normativa en seguridad de la información

- **Adecuación de la gestión según ISO 27000 al ENS**

Gestión en base a ISO/IEC 27000	Gestión en base al ENS
Tiene como objetivo el establecimiento de un sistema de gestión de la seguridad de la información (SGSI)	Regula los principios básicos y define los requisitos mínimos. Sólo obliga a implantar un auténtico SGSI en sistemas de categoría Alta
El alcance del SGSI viene definido por la propia organización	Afecta específicamente a los medios electrónicos utilizados por la Administración para relacionarse con los ciudadanos
Se enfoca hacia los recursos de forma general, sin limitarse a los sistemas de información	Se enfoca al sistema de información como conjunto organizado de recursos
No obliga a la implantación de medidas de seguridad concretas, sino a satisfacer controles	Obliga a implantar un conjunto determinado de medidas de seguridad, en base a la categoría del sistema
Obliga a la realización de auditorías periódicas	Obliga a una auditoría cada 2 años de conformidad con el ENS, en los casos de sistemas de categoría Media y Alta (Autoevaluación en Básica)